Information Security Compliance Risk and Governance Report

TO: Senior Leadership, Sandhaven University
FROM: Cybersecurity Risk and Governance Advisory
DATE: September 25, 2026
SUBJECT: Comprehensive Information Security Assessment and Strategic Compliance Plan Case Study RSN1

Task 1: Analysis of Current Cybersecurity Posture

A. Information Security Compliance Risk and Governance Evaluation

1. Identification of the Organization and Applicable Legal Frameworks

Organization Name: Sandhaven University (SU)

Relevant Laws and Regulations:

- **1. Family Educational Rights and Privacy Act (FERPA) (34 CFR Part 99):** Applies directly to Sandhaven University as an accredited California higher education institution operating under federal funding and student aid programs. FERPA regulates the management, privacy, and release of student education records, including transcripts, academic history, and personally identifiable information (PII).
- **2. Health Insurance Portability and Accountability Act (HIPAA) Security and Privacy Rules (45 CFR Parts 160 and 164):** Applies to Sandhaven University through its operation of student health services and on-campus medical clinics that collect, store, transmit, and maintain Electronic Protected Health Information (ePHI). SU functions as a hybrid entity under federal healthcare regulations.

1a. Regulatory Application to Sandhaven University Operational Vulnerabilities

- **FERPA Application:** The Registrar Office maintains physical and electronic student records with a staff of only three employees, resulting in a 90-day processing backlog. With 80% of student records still held in paper formats, staff struggle to validate identities and confirm proper consent prior to record distribution. Under 34 CFR Section 99.30, releasing educational records without verified consent or failing to maintain strict inspection logs directly breaches federal mandates. This administrative bottleneck exposes the university to regulatory non-compliance, potential loss of Department of Education funding, and civil enforcement actions.
- **HIPAA Application:** Sandhaven University maintains personal health information across campus clinics. Under HIPAA Security and Privacy Rules, the university must implement administrative controls, physical security, and technical safeguards including role-based access, audit logging, and data encryption for all ePHI. The university current structure delegates compliance responsibilities to individual system owners without central oversight, while four system administrators handle security as a secondary duty. This lack of centralized administrative control leaves student health data exposed to unauthorized access, opening the institution to Office for Civil Rights (OCR) financial penalties.

1b. Policy and Procedure Recommendations for Regulatory Compliance

Policies and Procedures for FERPA Compliance:

- **1. Mandatory Student Record Access and Release Procedure:** Implements a multi-step digital identity verification protocol for all manual and automated record inquiries handled by the Registrar Office. It mandates standard electronic consent verification and requires all releases to be logged automatically within the Student Information System (SIS). Standardizing the validation workflow resolves the 90-day backlog and removes paper-based human error.
- **2. Data Classification and Educational Record Handling Policy:** Categorizes university data into specific sensitivity tiers (Public, Internal, Confidential, Restricted) and sets explicit rules for storing, transferring, and destroying student PII in both digital and paper forms. Enforces uniform handling rules across all academic departments, eliminating informal storage of student transcripts on local workstations or unapproved cloud drives.

Policies and Procedures for HIPAA Compliance:

- **1. ePHI Technical Safeguards and Encryption Policy:** Enforces end-to-end AES-256 encryption for all health clinic records at rest and in transit, while requiring multi-factor authentication (MFA) and role-based access controls for any system containing ePHI. Addresses HIPAA Security Rule standards (45 CFR Section 164.312) by ensuring health data remains inaccessible to unverified personnel, network administrators without a medical business need, or external actors.
- **2. Vendor Risk Management and Business Associate Agreement (BAA) Operating Procedure:** Establishes mandatory security evaluations and legally binding BAAs for every third-party software vendor, cloud host, or contractor interacting with university healthcare systems prior to onboarding. Fulfills 45 CFR Section 164.502(e) requirements by guaranteeing third-party software partners adhere to statutory healthcare privacy and security standards.

2. Potential Threat Events and Comprehensive Risk Analysis

Risk Assessment Scoring Criteria: To determine the overall level of risk for identified threats, ratings are derived by evaluating the likelihood of event occurrence against the severity of potential business impact:

- **- High Likelihood paired with High Impact:** Yields a Very High Risk rating.
- **- High Likelihood paired with Very High Impact:** Yields a Very High Risk rating.
- **- Moderate Likelihood paired with High Impact:** Yields a High Risk rating.
- **- Low Likelihood paired with Moderate Impact:** Yields a Moderate Risk rating.

Threat Event 1: Enterprise Account Takeover via Credential Spraying and Password Exploitation

- **Associated Vulnerability:** The password policy has remained unrevised since 2012, requiring a minimum length of only 6 characters with no complexity rules, no credential history tracking, and an annual rotation cycle. Furthermore, the 2023 Acceptable Use Policy update allowed personal email, social media, and public artificial intelligence tools on university networks.
- **Threat Event Description:** An external threat actor launches automated credential spraying attacks against public-facing university portals and cloud systems. Capitalizing on short, simple 6-character passwords, the attacker compromises user accounts, penetrates internal networks, and gains access to administrative user groups.

- **Likelihood Rating:** High - Simple 6-character passwords can be cracked or guessed in seconds using automated tools. Because four network administrators manage security as a secondary duty without a dedicated Security Operations Center (SOC) or centralized event logging system, the probability of an attack occurring and going undetected until damage occurs is High.
- **Impact Rating:** High - Compromising user accounts allows adversaries to access sensitive student PII, health files, and proprietary National Science Foundation grant research. The event would trigger regulatory notification obligations, cause financial loss, and harm institutional standing.
- **Level of Risk:** VERY HIGH
- **Risk Management Approach:** Replace the legacy 2012 password framework with a policy requiring minimum 14-character passphrases, mandate multi-factor authentication (MFA) across all remote and cloud systems, and implement an automated identity management solution to flag anomalous authentication attempts.

Threat Event 2: Ransomware Infection and Enterprise System Disruption

- **Associated Vulnerability:** The 2024 Disaster Recovery Plan (DRP) focuses primarily on contact lists and notification routes without technical recovery steps for cyber incidents; systems lack centralized security monitoring and patch management; four IT employees manage all operations; and user account access audits occur only once every 24 months.
- **Threat Event Description:** An attacker delivers ransomware through a malicious attachment or an unpatched vulnerability in a public-facing system. The malware spreads laterally, encrypting cloud systems, student information databases, and local research repositories, rendering core applications unusable.
- **Likelihood Rating:** High - Academic institutions are frequent targets for malware campaigns. Sandhaven University lack of unified monitoring, patch management software, and security specialization creates an environment where malicious code can execute and spread without immediate intervention.
- **Impact Rating:** Very High - Ransomware halts instructional activities, disables third-party financial processing portals, locks research databases, and disrupts administrative offices. Because the DRP lacks technical recovery workflows, system restoration could take weeks, violating the university target of 99% uptime for student systems.
- **Level of Risk:** VERY HIGH
- **Risk Management Approach:** Build isolated, immutable offsite backups; update the Disaster Recovery Plan with step-by-step cyber Incident Response procedures; run annual restoration drills; deploy Endpoint Detection and Response (EDR) agents across all endpoints; and engage a Managed Detection and Response (MDR) provider for 24/7 monitoring.

3. Information Security Policy Modifications for Governance Enhancement

- **Modification 1 (Acceptable Use Policy & AI Governance):** Revise the 2023 Acceptable Use Policy to impose explicit operational boundaries on public artificial intelligence platforms, personal email, and social media tools on university systems. Explicitly forbid entering student PII, ePHI, financial transactions, or grant research data into unvetted public AI platforms. Prevents data exposure risks and preserves research confidentiality and integrity.
- **Modification 2 (Continuous Account Lifecycle Governance):** Replace the legacy standard operating procedure with an automated Account Lifecycle and Access Governance Policy requiring bi-weekly automated account synchronization with HR/Registrar databases and

quarterly access reviews for elevated administrative privileges. Enhances integrity and availability by eliminating orphaned/unmonitored accounts.

Action Plan and Strategic Timeline

- **Phase 1: Immediate Remediation (Months 1-2):** Enforce 14-character minimum passphrases within Days 1-15; mandate MFA within Days 16-30; publish updated AUP for AI usage within Days 31-60.
- **Phase 2: Operational Capabilities and Alignment (Months 3-4):** Contract a 24/7 MDR vendor within Days 61-90; automate Registrar record validation within Days 91-105; adopt formal HIPAA ePHI safeguard policies within Days 106-120.
- **Phase 3: Long-Term Governance and Resilience (Months 5-6):** Revise the Disaster Recovery Plan for cyber incidents within Days 121-150; deploy automated user account auditing tools within Days 151-180.

Direct Executive Next Steps

- **1. Executive Policy Adoption:** Present the revised Acceptable Use Policy and Account Lifecycle Policy to the Board of Trustees for formal adoption during the next executive session.
- **2. Operational Support:** Partner with a Managed Detection and Response (MDR) provider to handle continuous network monitoring, relieving the four-person IT staff of dual operational and security responsibilities.
- **3. Workflow Digitization:** Complete the transition of student paper files to the automated third-party record system within 60 days to resolve the 90-day processing backlog and ensure full consent tracking.

References

- Family Educational Rights and Privacy Act (FERPA), 20 U.S.C. Section 1232g; 34 CFR Part 99.
- Health Insurance Portability and Accountability Act of 1996 (HIPAA) Security and Privacy Rules, 45 CFR Parts 160 and 164.
- National Institute of Standards and Technology. (2012). Conducting Risk Assessments (NIST Special Publication 800-30, Revision 1). U.S. Department of Commerce.
- National Institute of Standards and Technology. (2020). Security and Privacy Controls for Information Systems and Organizations (NIST Special Publication 800-53, Revision 5). U.S. Department of Commerce.